

Federated Learning и Privacy-Preserving архитектура

AI Архитектор



Проверить, идет ли запись

Меня хорошо видно
& слышно?





Андрей Носов

Ведущий AI-архитектор, Рафт

- 13 лет в разработке решений на основе NLP и GenAI
- PhD Communication Sciences, Tampere University
- Руководитель школы AI-архитекторов OTUS

 @parallelnominded

 andrey.nosoff@gmail.com



Правила вебинара



Активно
участвуем

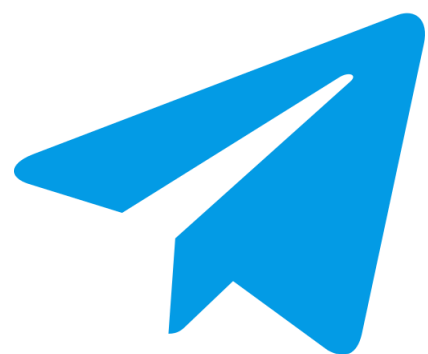


Задаем вопрос
в чат или голосом



Вопросы вижу в чате,
могу ответить не сразу

Правила вебинара

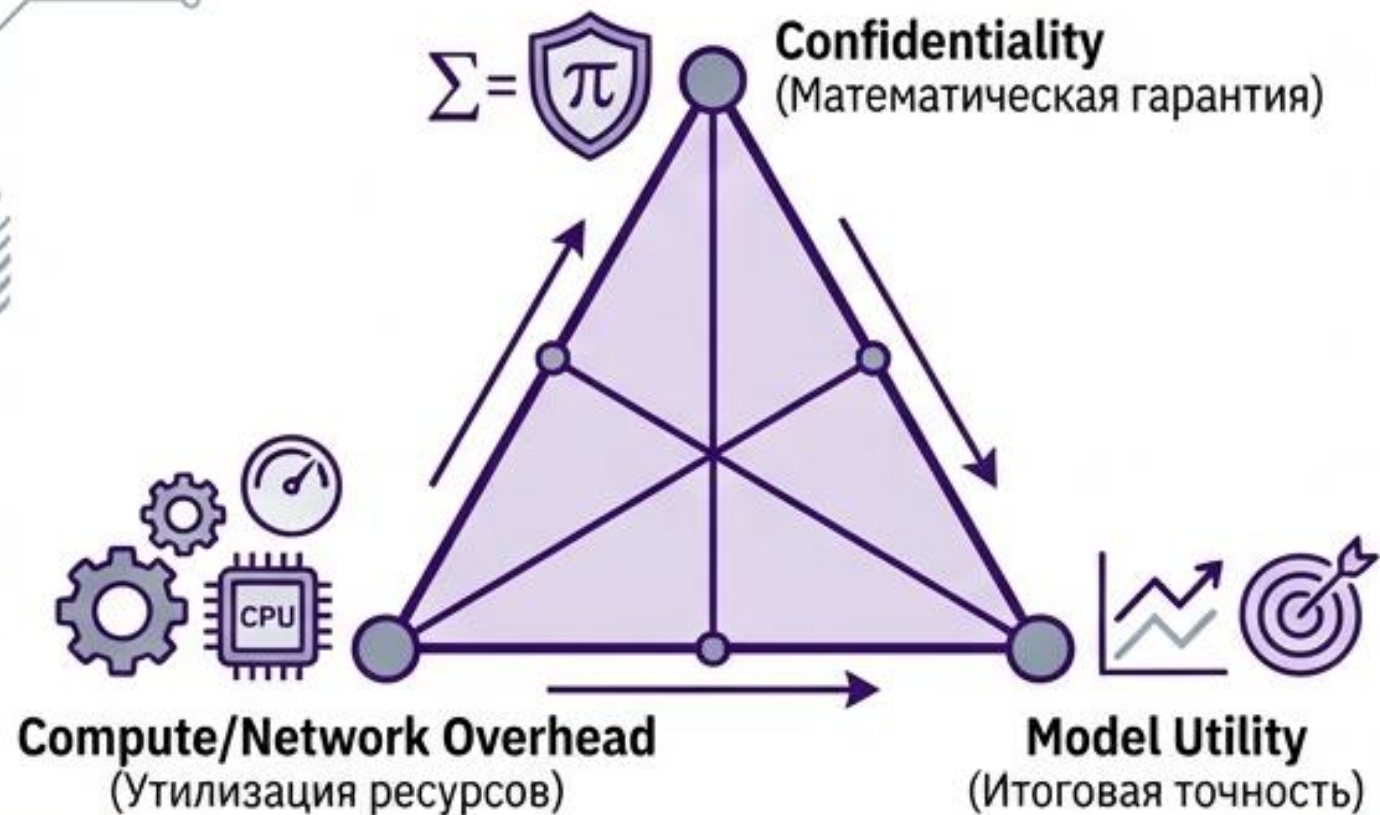
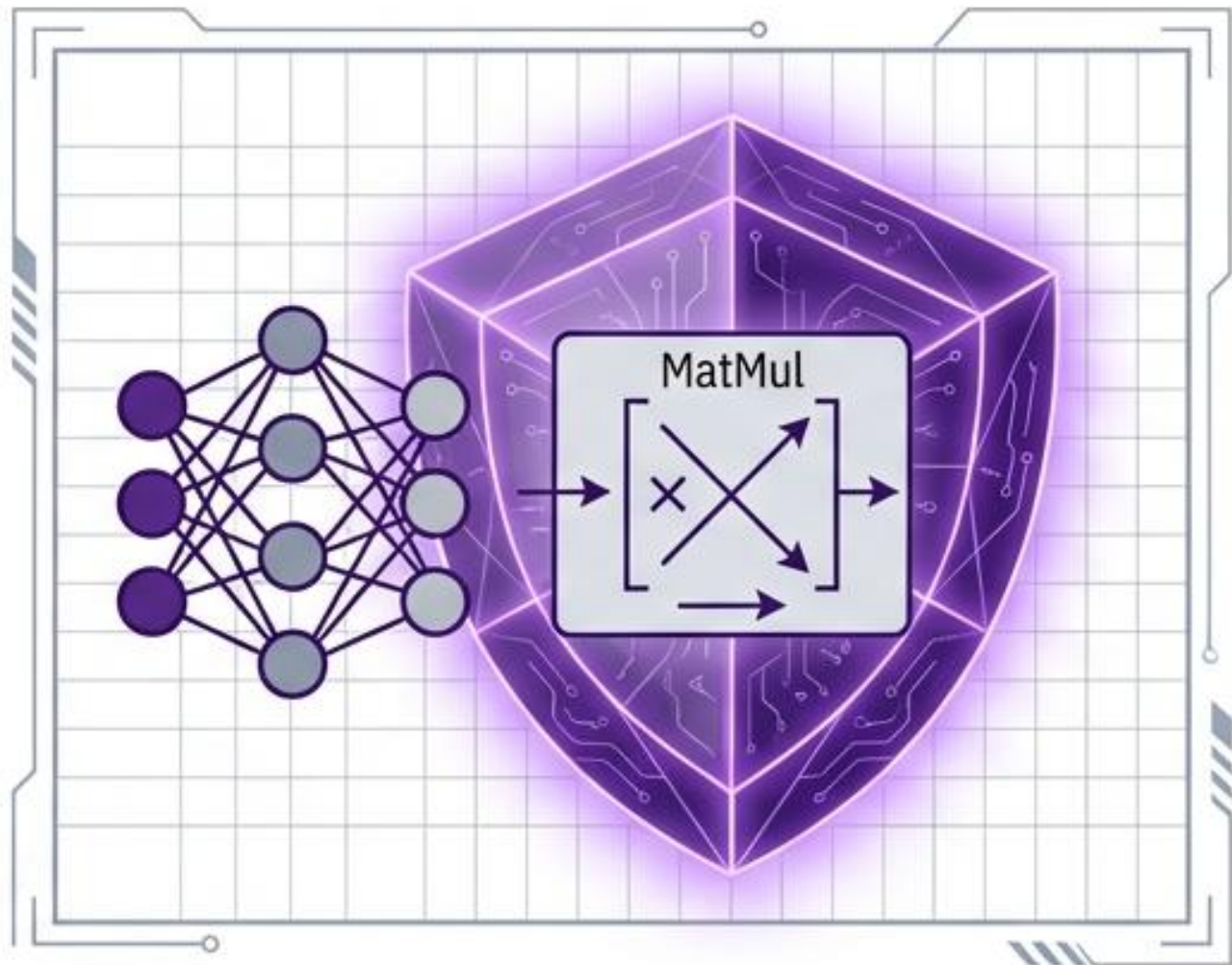


Off-topic обсуждаем
в закрытом чате в Telegram

Кто еще не присоединился,
сканируйте QR код :)



Концепция Privacy-Preserving Architecture (PPA) в ИИ



Суть PPA	Исключение компрометации сырых данных, весов и инференс-запросов. Центральный сервер никогда не видит данные в plaintext.
Принцип Data Minimization	Защита от root-доступа. Даже скомпрометированный администратор гипервизора не сможет извлечь признаки из оперативной памяти.
Проектирование	PPA не разворачивается «из коробки». Это модульный конструктор под конкретный профиль угроз, фиксируемый в Architecture Decision Record (ADR).

PPA Ecosystem

Статистические методы

Ядро: Differential Privacy (DP).

Функция:
Математическая гарантия неразглашения факта присутствия конкретной записи в датасете.

Алгоритмические подходы

Ядро: Federated Learning (FL) и Split Learning.

Функция:
Распределенное обучение. Сырые данные физически не покидают периметр владельца.

Криптографические методы

Ядро: SMPC, FHE, TEE.

Функция:
Математические операции непосредственно над зашифрованными данными.

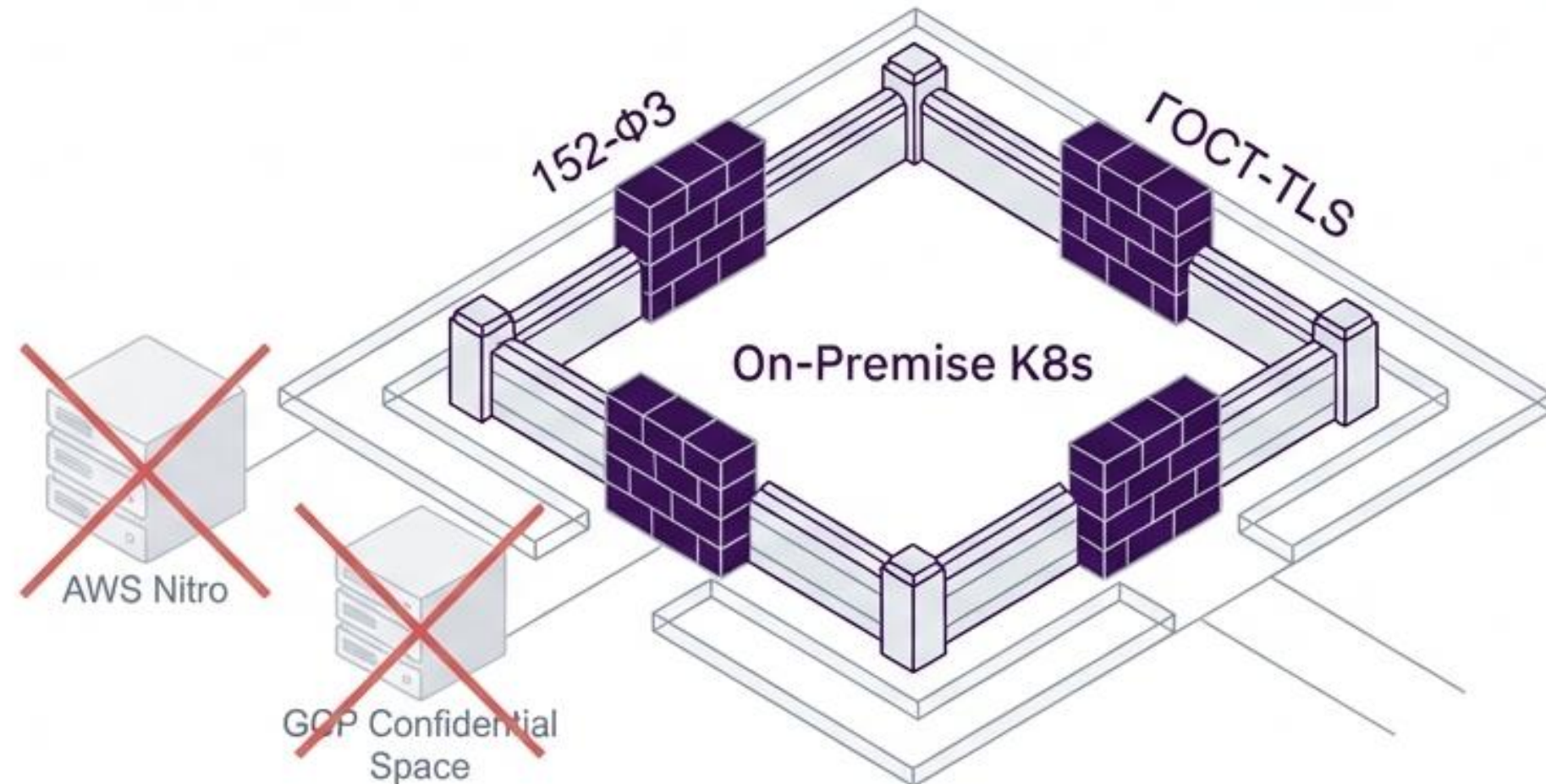
Правило гибридизации

Ни один подход не защищает на 100%. **Пример:** FL уязвим к реконструкции градиентов.
Решение: FL + Local DP (падает сходимость) или FL + SMPC (экспоненциальный рост нагрузки на сеть).
Задача архитектора — вписать стек в Hardware Budget.

Законодательный и инфраструктурный контекст РФ в 2026 году

Регуляторные драйверы

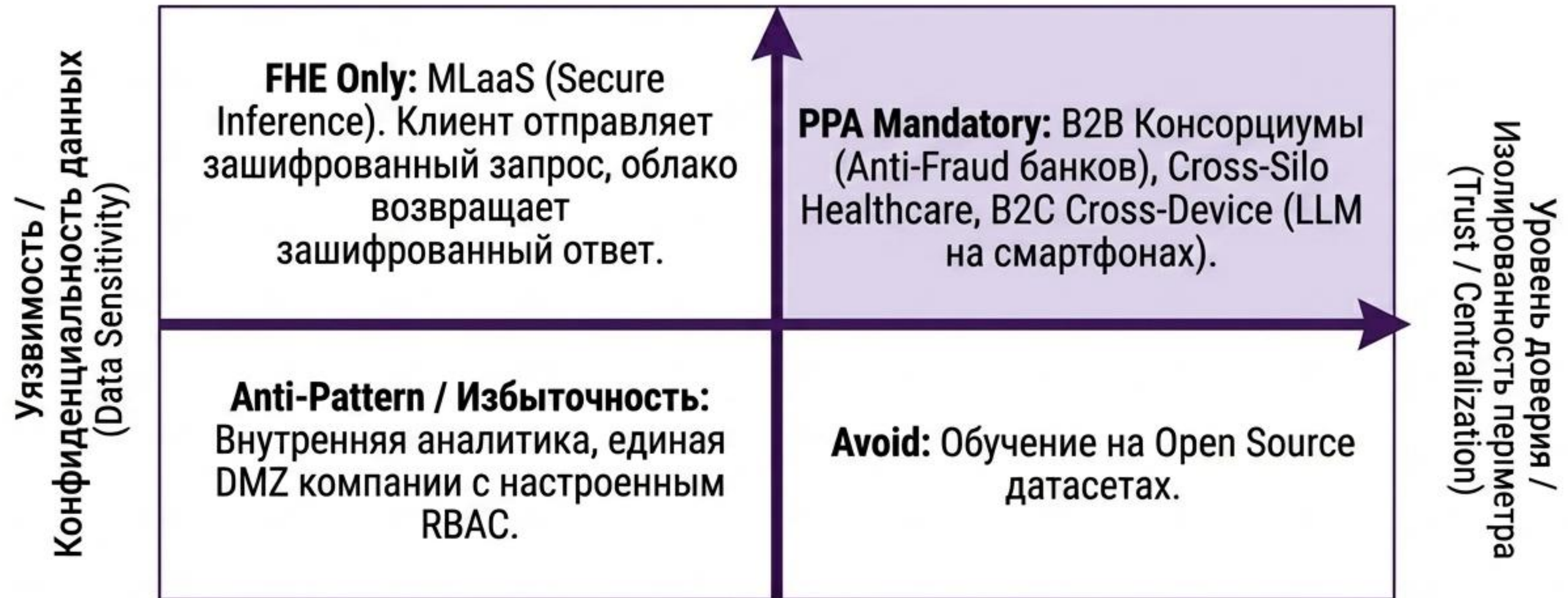
- Жесткие требования регуляторов (152-ФЗ, приказы ФСТЭК №17/21, ФСБ).
- Передача медицинских (ЕГИСЗ) или банковских данных в центральные Data Lakes невозможна без PPA, так как классическое обезличивание легко обратимо ИИ.



Инфраструктурная реальность

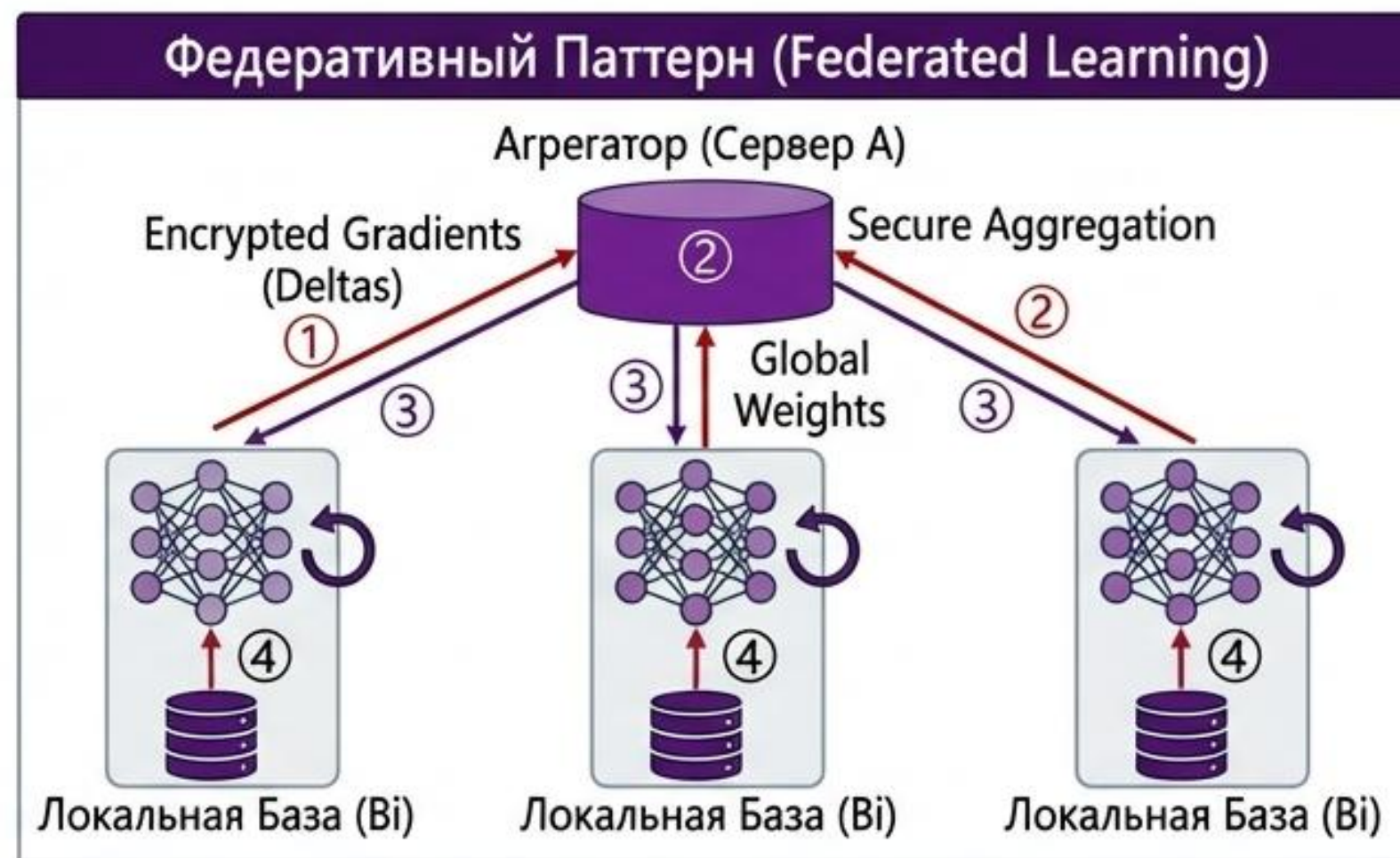
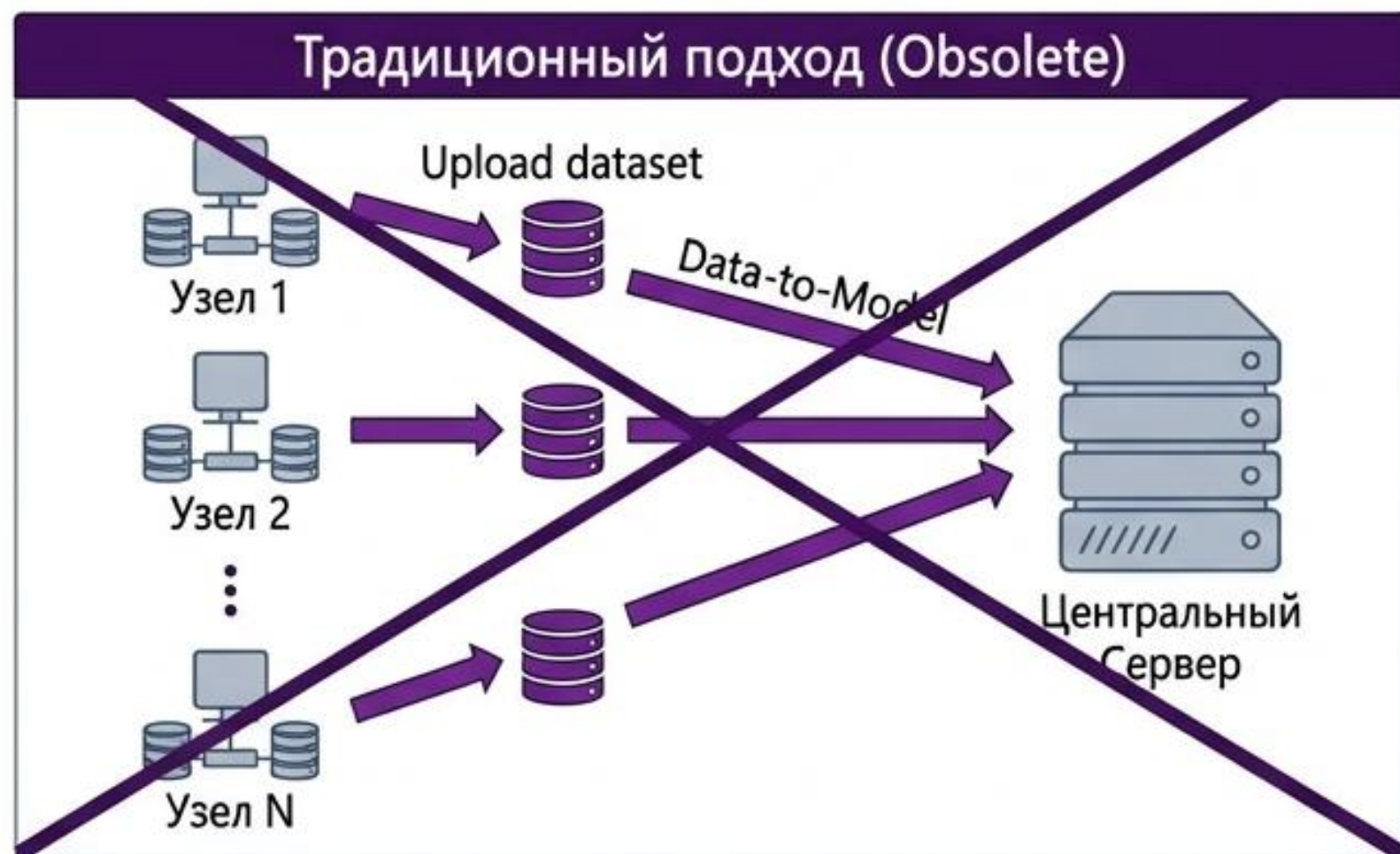
- **Strictly On-Premise:** Недоступность западных TEE (Intel SGX/TDX) в госсекторе из-за санкций. Фокус смещен на криптографию (FL, SMPC).
- **ГОСТ-Транспорт:** Взаимодействия оборачиваются в ГОСТ-TLS на уровне Service Mesh. ГОСТ-шифрование несовместимо с гомоморфными вычислениями (FHE).
- **Оркестрация:** Vanilla K8s / Deckhouse поверх Astra Linux / RED OS. Требуется компенсация крипто-оверхеда за счет отечественных NPU/GPU.

Границы применимости PPA: Необходимость против Избыточности



Осторожно: Over-engineering. PPA — самое дорогое архитектурное решение (рост FLOPS в 10-100 раз). При критичном Time-to-Market (TTM) и среднем уровне секретности **выбирайте классическую централизацию.**

Паттерн проектирования: Введение в Federated Learning (FL)



Инверсия MLOps

Вместо сбора логов, сервер отправляет модель (веса) на периферию к источникам данных.

Раунды агрегации

Агрегатор рассылает глобальные веса. Клиенты проводят локальное обучение.

Изоляция данных

На сервер возвращаются только градиенты (Deltas).

Новые вызовы системы

Разная мощность узлов, распределения Non-IID, новая точка отказа (SPOF на сервере) и угроза Model Poisoning.

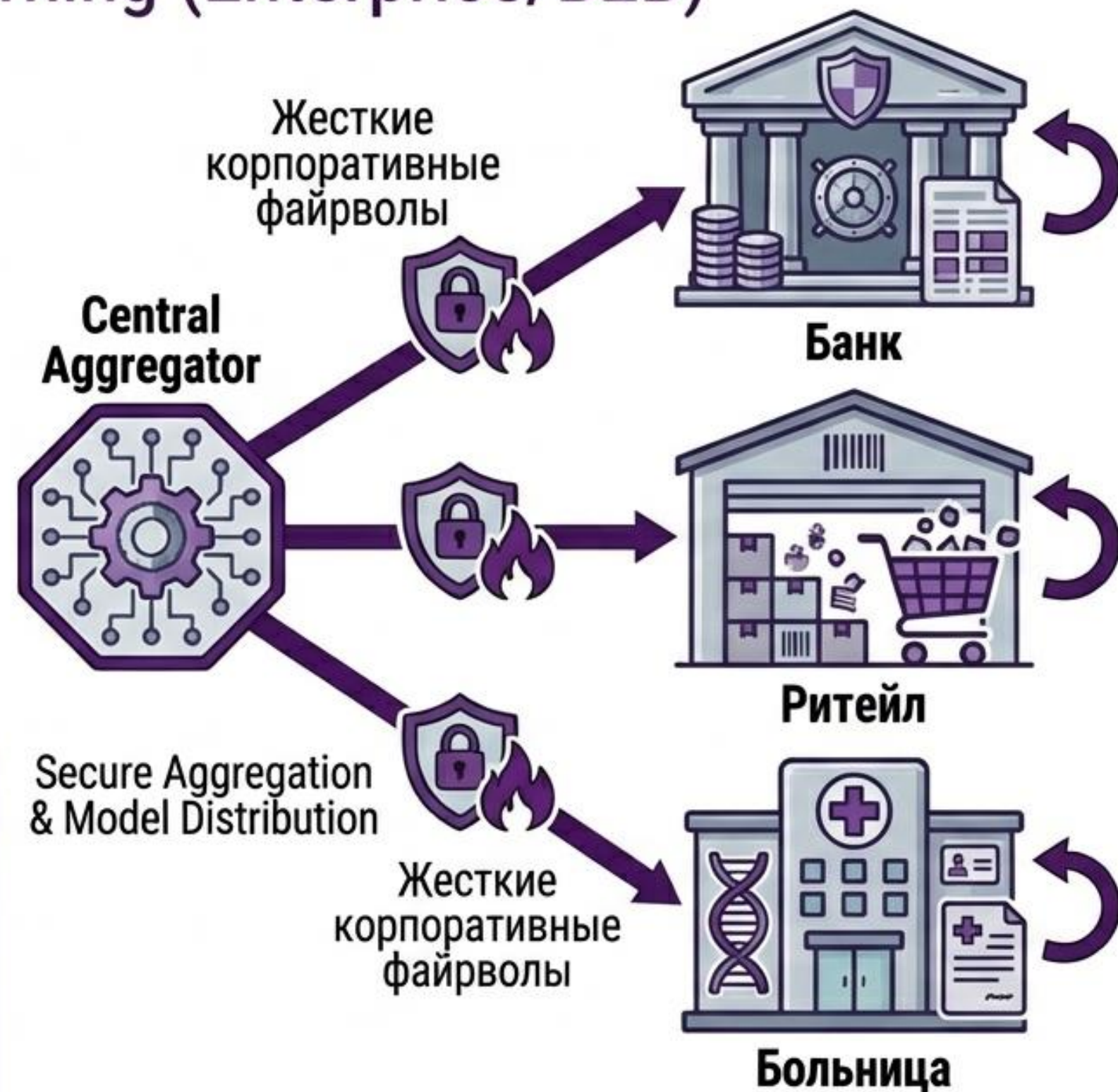
Паттерн: Cross-Silo Federated Learning (Enterprise/B2B)

Архитектурные характеристики

- **Масштаб:** 2–100 узлов. Огромные массивы данных и локальные GPU-кластеры.
- **Сеть:** Высокая пропускная способность, но жесткие корпоративные файрволы (Reverse Proxies, Ingress/Egress политики, mTLS, интеграция с Keycloak/AD).
- **Надежность:** Выбывание одного узла (Node Dropout) критично. Требуются Stateful-сессии и строгий Checkpointing.

Ключевой вызов: Data Alignment & Entity Resolution

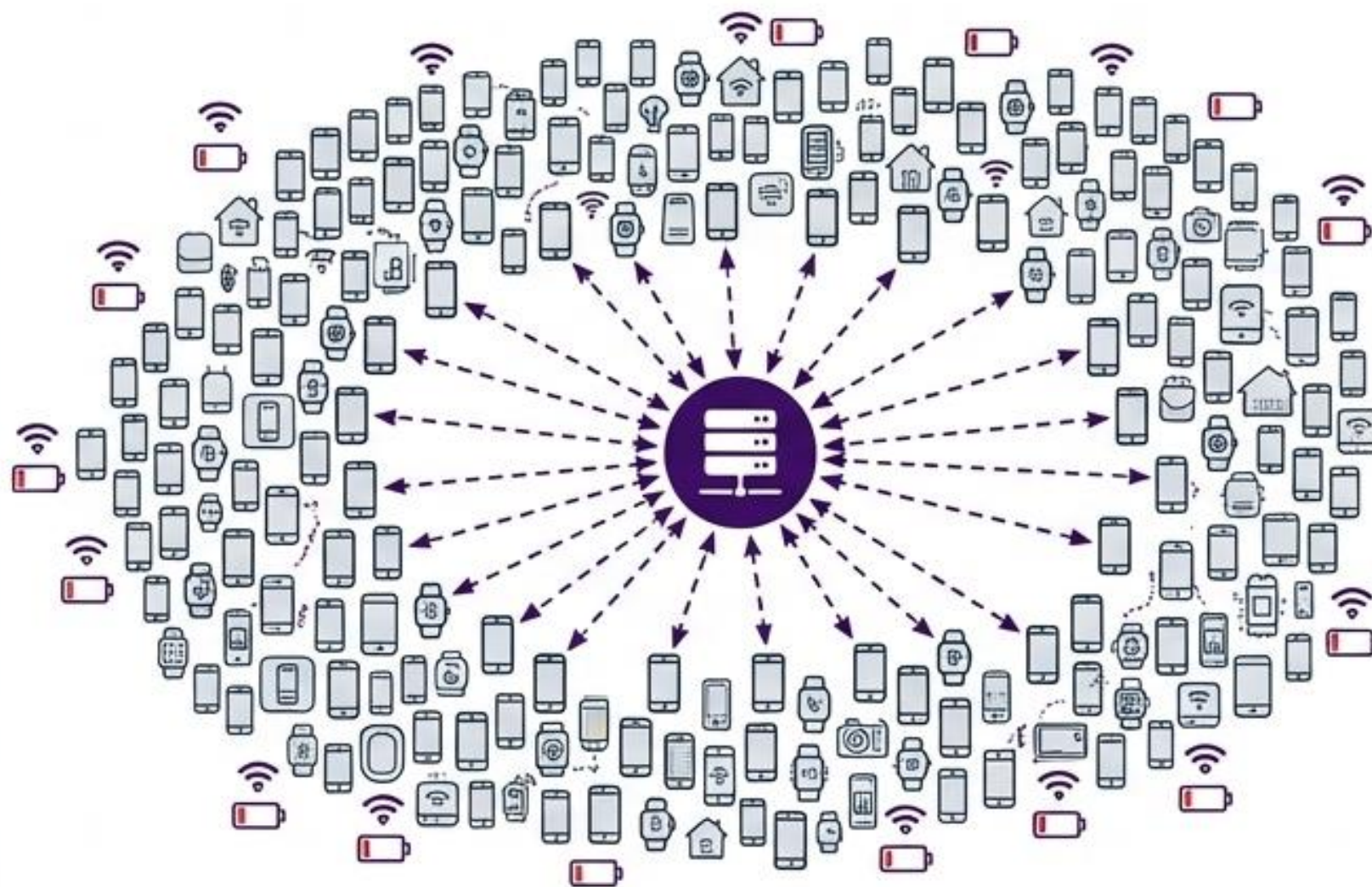
Выравнивание схем данных участников и поиск пересечений пользователей в Vertical FL (когда у банков разные признаки одних клиентов), **не раскрывая самих баз.**



Паттерн: Cross-Device Federated Learning (B2C/Edge)

Архитектурные характеристики

- **Масштаб:** Миллионы маломощных устройств. Инфраструктура предельно нестабильна.
- **Триггеры обучения:** Строгий Idle State (устройство на зарядке, с Wi-Fi, не используется).
- **Агрегация:** FedAsync (Asynchronous FL). Балансировщики не ждут всех, так как Dropout Rate достигает 90%.



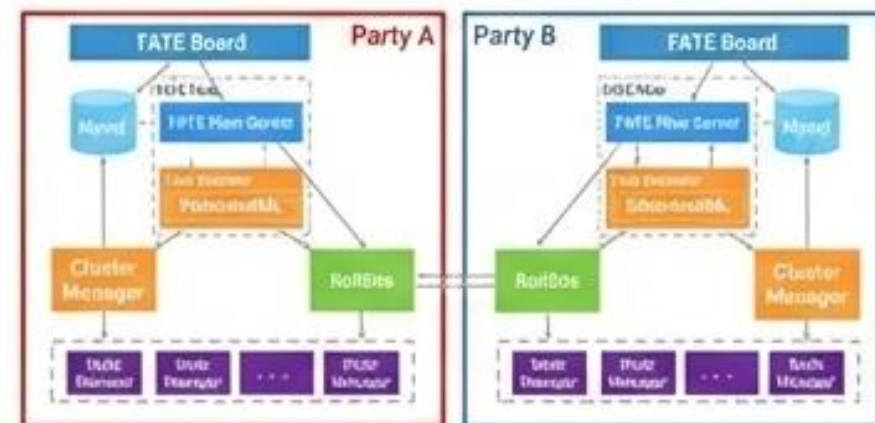
Оптимизация и Защита

RAM Constraints: Использование квантования весов (INT8/INT4), дистилляции и передачи только LoRA-адаптеров.

Безопасность: Secure Aggregation (SecAgg) обязательна, чтобы сервер видел только сумму градиентов от групп (~1000 устройств), а не индивидуальный телефон.

Сравнение фреймворков для Federated Learning

Фреймворк	Позиционирование	Особенности	Минусы
Flower (flower.ai)	Индустриальный стандарт	Агностик к PyTorch/TF. Высокая масштабируемость.	Криптография (SecAgg) и MLOps настраиваются вручную.
OpenFL (Intel)	B2B / Медицина	Встроенная PKI аутентификация. Нативная поддержка DICOM и TEE.	Жесткая привязка к Envoy, меньше гибкости топологий.
FATE (WeBank)	Тяжелый Enterprise	Всё-в-одном (встроенные HE, MPC). Идеально для Vertical FL банков.	Переусложненная монолитная архитектура, сложность деплоя в K8s.
PySyft	Research / Data Gov	Концепция утверждения операций владельцем. Простой Python API.	Низкая производительность в High-Load production.



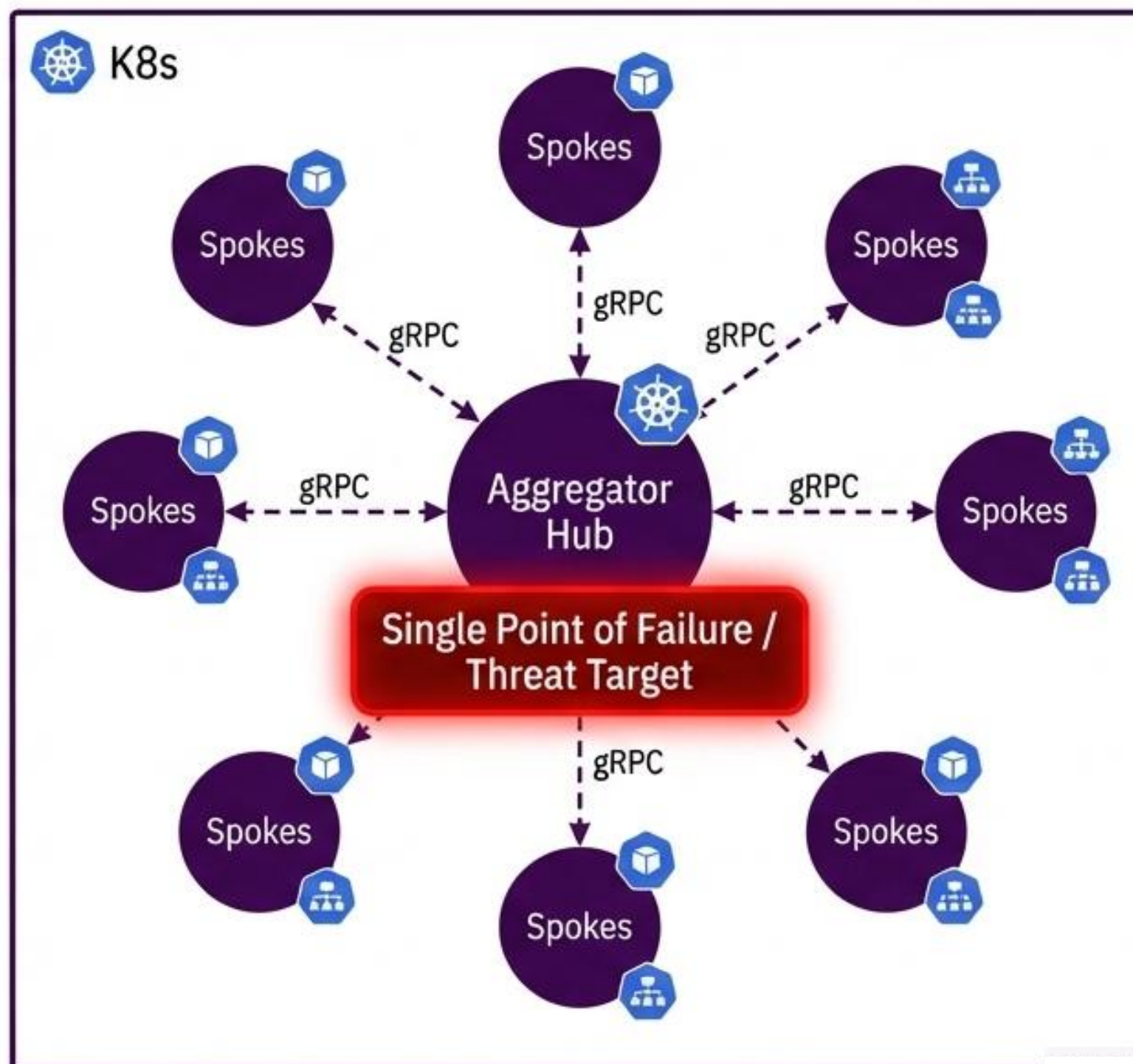
Архитектурный паттерн: Centralized (Hub-and-Spoke) FL

Дизайн Control Plane

- Hub оркестрирует раунды, поддерживает Service Discovery, рассылает триггеры.
- Упрощает управление ключами (KMS) и обновлениями у единого ИТ-интегратора.
- Spokes устанавливают исходящие соединения к Hub, обходя проблемы с входящими NAT.

Риски и Решения

- Уязвимость: DDoS атаки или обрыв связи роняют всю сеть. Хаб — главная мишень для кражи агрегированных данных.
- Mitigation: Hub проектируется строго как Stateless-сервис. Состояние сессий переносится в in-memory БД, веса сохраняются в on-prem S3 (MinIO).



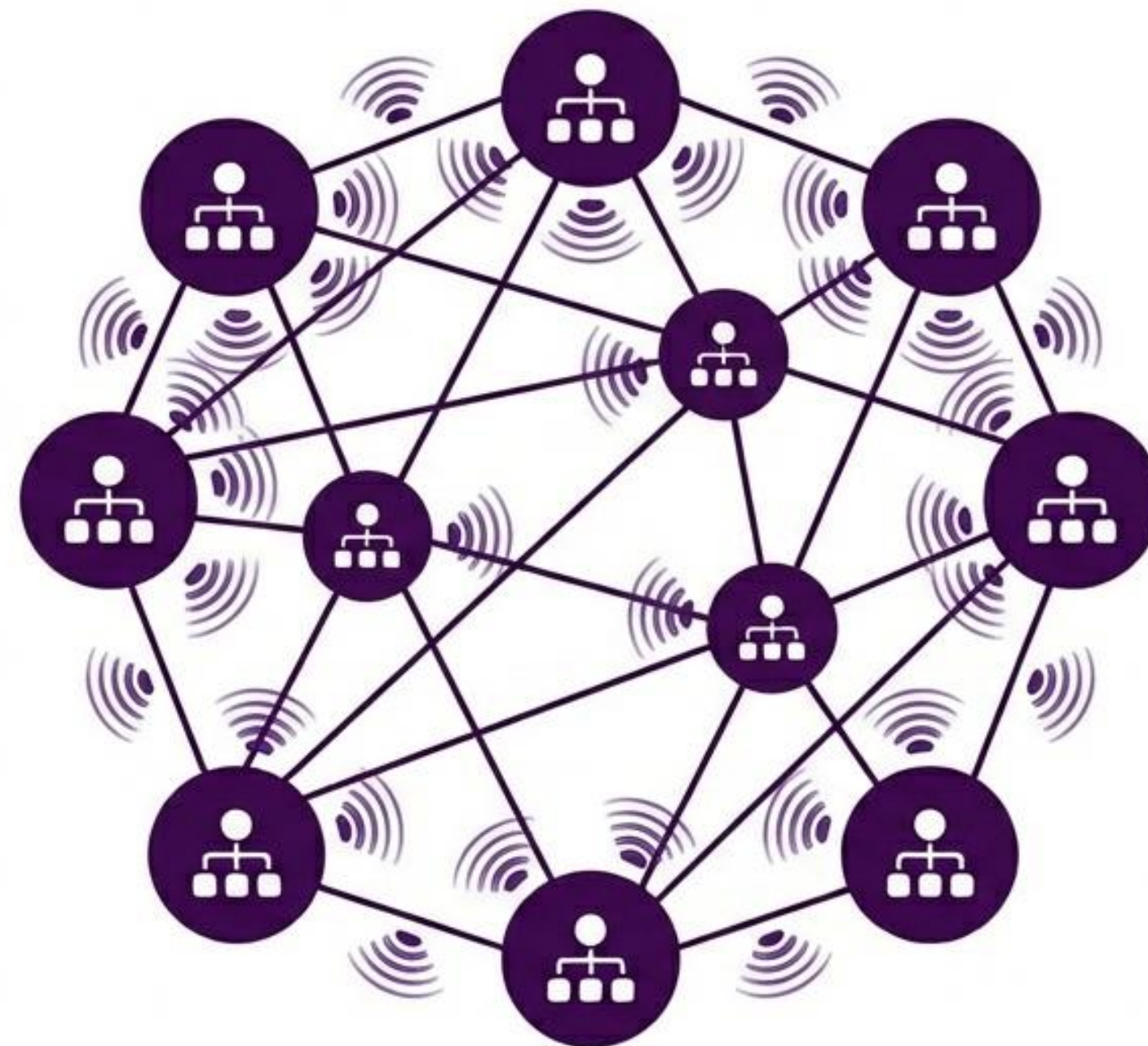
Архитектурный паттерн: Decentralized (Peer-to-Peer / Gossip) FL

Дизайн Control Plane

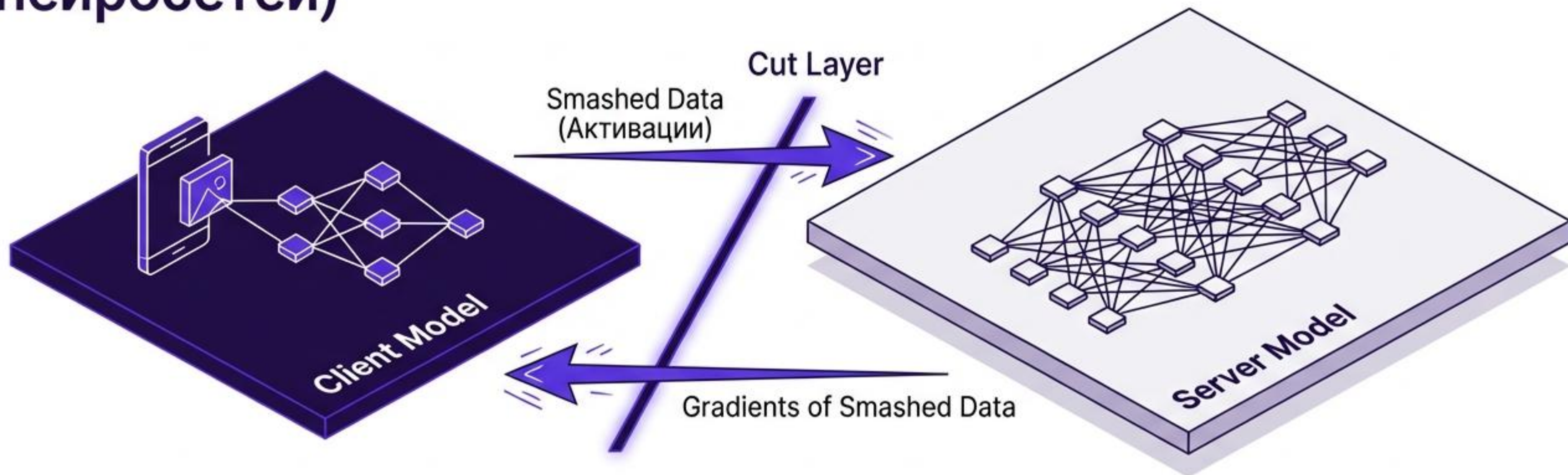
- Fully Decentralized. Оркестратор распределен. Используются Gossip-протоколы и алгоритмы Push-Sum.
- Связанность «каждый-с-каждым» обеспечивается через Mesh-сети (WireGuard, Nebula) поверх корпоративных фаерволов.

Риски и Преимущества

- Преимущества: Максимальная отказоустойчивость (Partition Tolerance). Сеть сходится даже при падении 30% узлов. Нет единой точки доверия (No Single Point of Trust) — идеально для конкурирующих банков.
- Риски: Чудовищный Network Overhead. Увеличение времени сходимости в разы. Сложный распределенный мониторинг. Часто является Over-engineering.



Паттерн: Split Learning (Разделенное обучение нейросетей)



Суть архитектуры:

Разделение графа нейросети (Deep Neural Network) на Cut Layer. Сырые данные никогда не покидают периметр клиента.

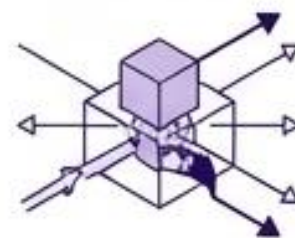
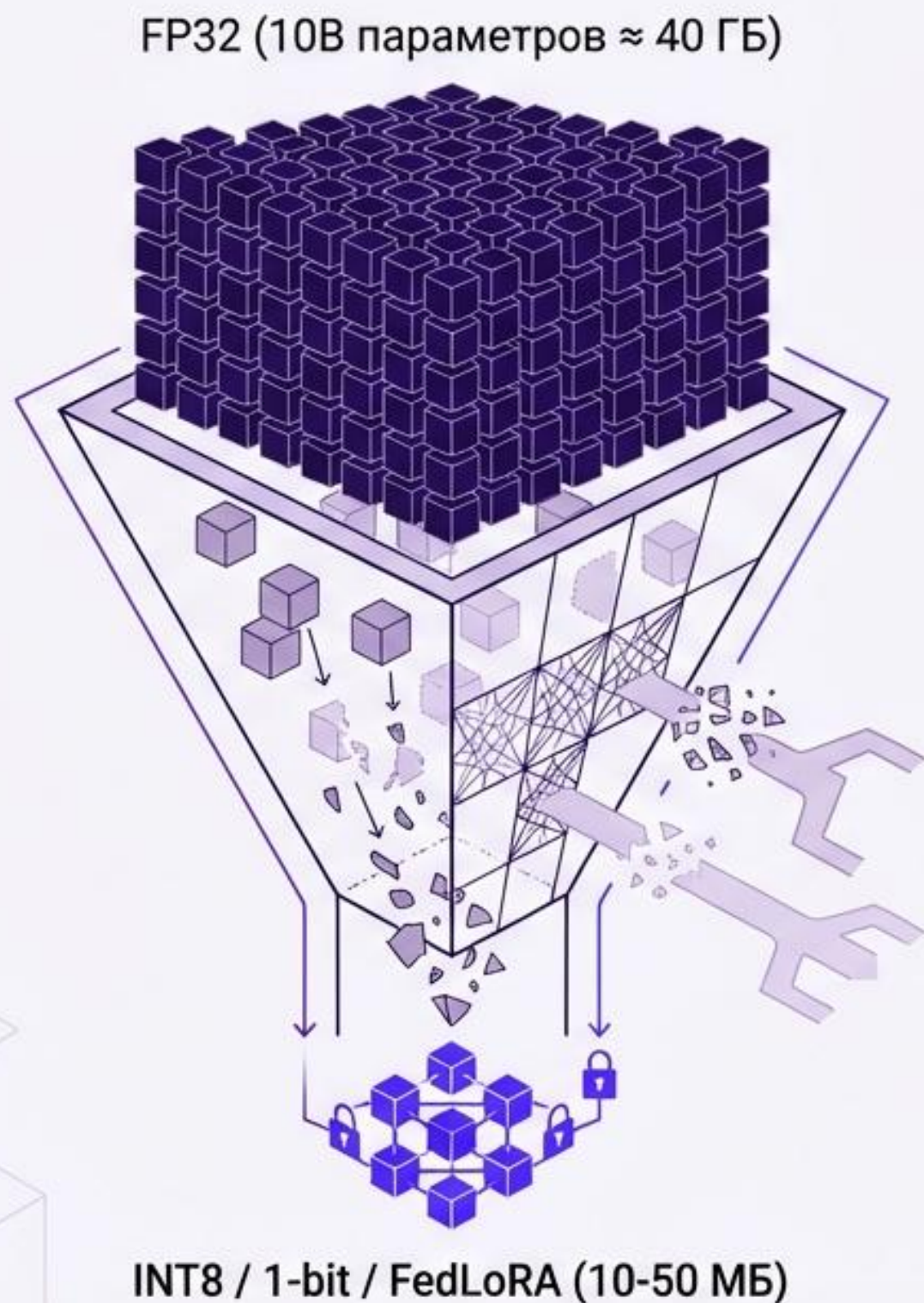
Преимущества:

Кардинальное снижение требований к RAM/VRAM на клиентах. Позволяет обучать LLM (напр. 70B параметров) с использованием слабых edge-устройств.

Уязвимости (Trade-off):

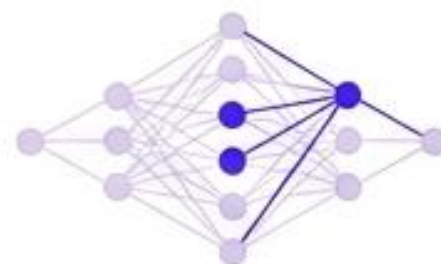
Synchronous Bottleneck (блокировка вычислений из-за Network Latency) и риск Model Inversion (восстановление сырых данных по активациям).

Векторное квантование и сжатие в RPA сетях



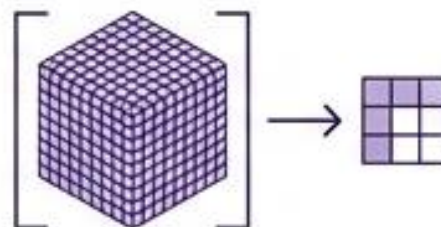
Архитектурная проблема

Передача гигантских объемов градиентов вызывает сетевой коллапс в WAN-сетях.



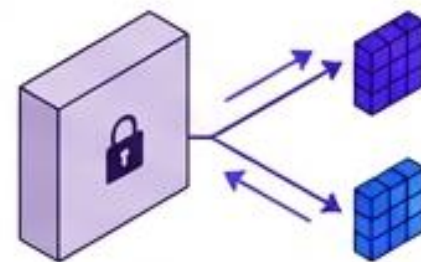
Sparsification (Прореживание)

Передача только Top-1% градиентов с наибольшими значениями. Остальные аккумулируются локально.



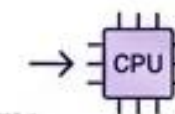
Vector Quantization

Снижение точности весов с FP32 до INT8 или бинарных значений, кардинально уменьшая Payload.



FedLoRA

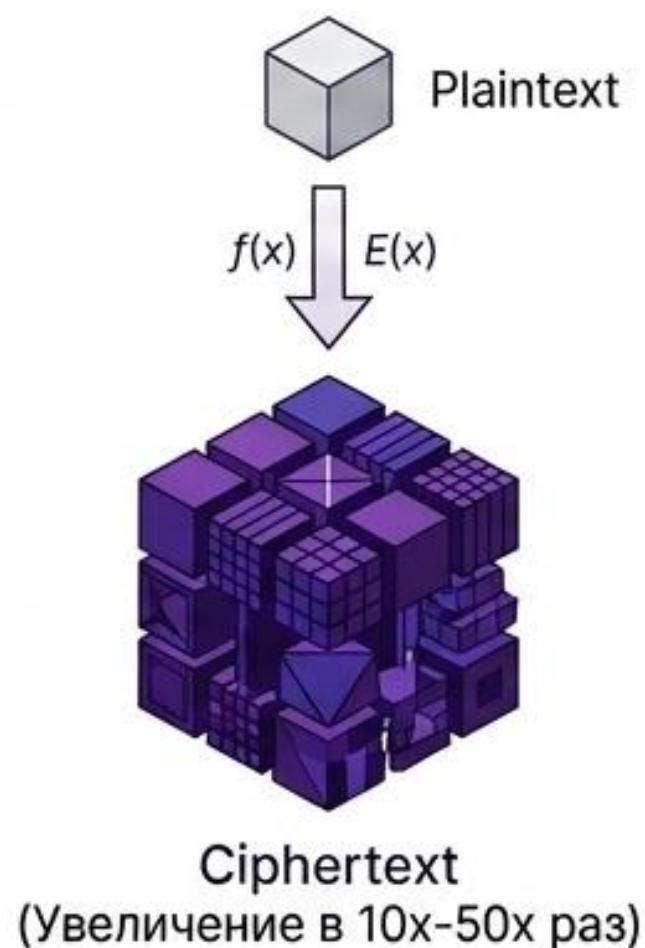
Основная LLM заморожена; по сети синхронизируются только легковесные матрицы-адаптеры. Скрытая цена: перенос нагрузки на CPU клиента (операции Quantize/Dequantize).



Криптография в РРА: Fully Homomorphic Encryption (FHE)

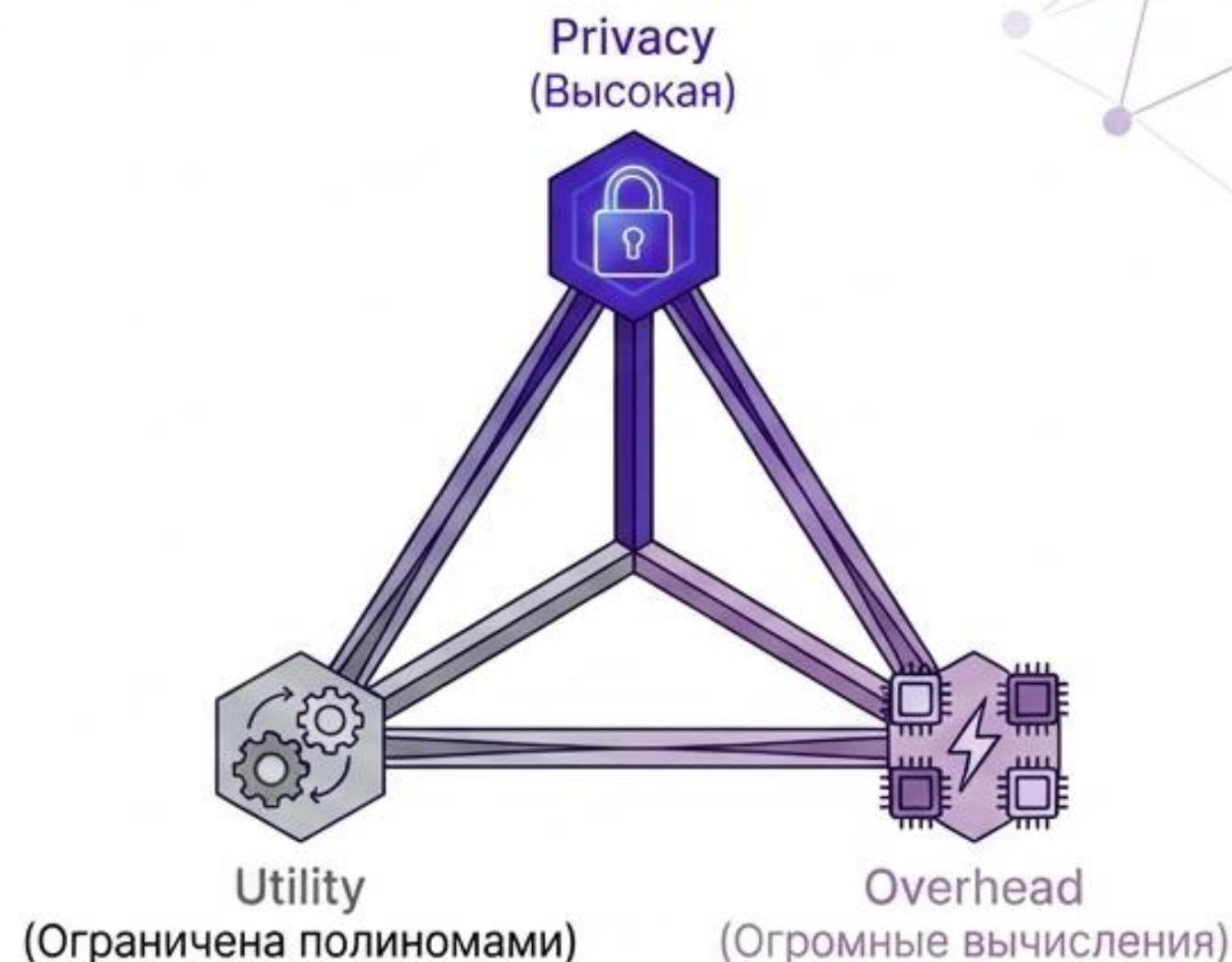
$$f(E(x)) = E(f(x))$$

Ciphertext Expansion



Святой Грааль ИИ: Тьюринг-полные вычисления поверх зашифрованных данных (Ciphertext) без расшифровки на недоверенном сервере (Zero Trust).

Математическая база: Post-Quantum Cryptography на решетках (LWE / Ring-LWE). Схемы BGV/BFV для целых чисел, CKKS для чисел с плавающей точкой.



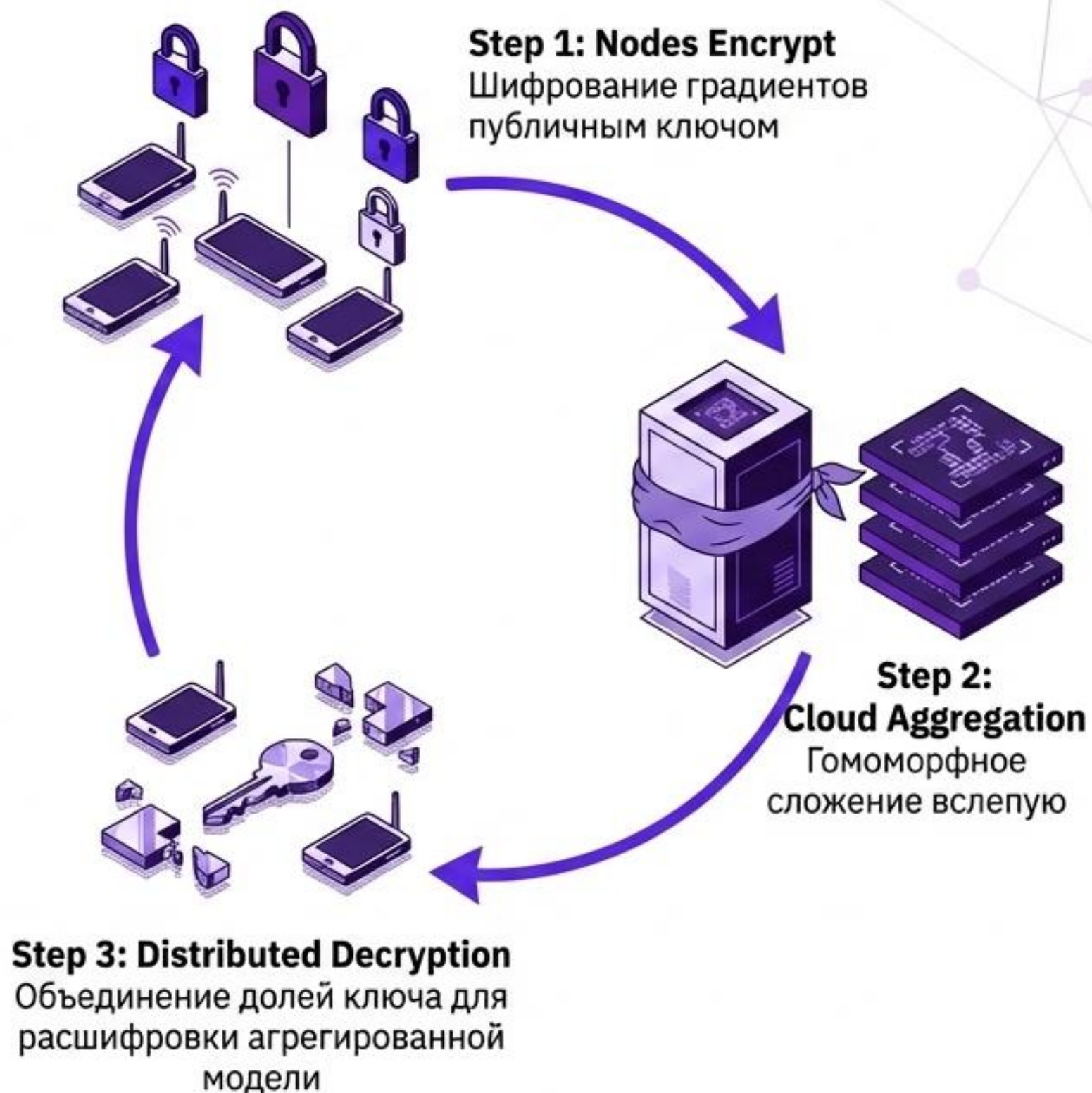
Архитектурный барьер: Замедление вычислений в 100–10000 раз. Необходимость замены функций активации (ReLU, Sigmoid) на полиномиальные аппроксимации.

Сравнение библиотек и компиляторов FHE

Фреймворк	Язык / ЦА	Главная фишка	Оверхед
Zama (Concrete ML)	Python, ML-инженеры	Встроенный Concrete Compiler (PyTorch/ONNX → TFHE)	Высокий (гигабайты RAM в runtime)
TenSEAL	C++/Python, Исследователи	Фокус на CKKS для тензорных вычислений	Средний (разработка прекращена)
HElib (IBM)	C++, Криптографы	Фундаментальные алгоритмы Bootstrapping (очистка шума)	Крайне высокий порог входа
Lattigo	Go, Backend- архитекторы	Высокая производительность и concurrency (go-routines)	Низкий (но мало ML- абстракций)

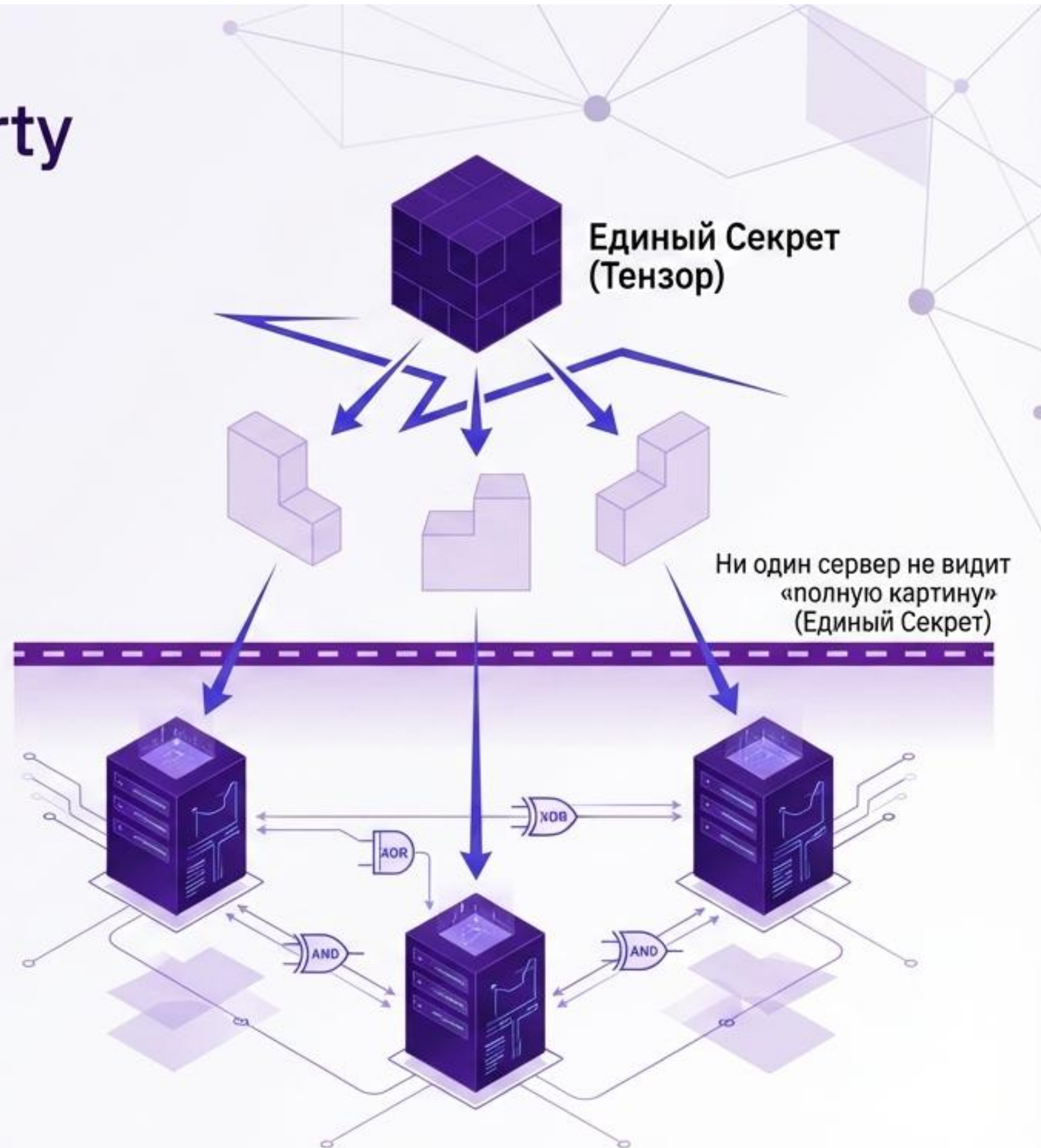
Паттерн: Secure Aggregation с использованием FHE

- **Защита от Model Inversion:** Центральный сервер-агрегатор оперирует исключительно зашифрованными матрицами, исключая утечку через plaintext-градиенты.
- **Threshold Cryptography:** Приватный ключ разделен между участниками (Shamir's Secret Sharing); сервер не обладает ключом дешифровки.
- **Архитектурный компромисс (Trade-off):** Избыточно (Over-engineering) для Cross-Device систем с телефонами. Применяется в B2B-консорциумах из-за колоссальной сетевой нагрузки (увеличение тензоров в десятки раз из-за схемы CKKS).



Технология Secure Multi-Party Computation (SMPC)

- **Распределенное доверие:** Узлы совместно вычисляют функцию, обмениваясь только математическими «долями» (Shares), не раскрывая сами данные (Oblivious Transfer, Garbled Circuits).
- **Преимущество перед FHE (CPU Efficiency):** Требуется базовая модульная арифметика (XOR/AND). В сотни раз меньше затраты на CPU.
- **Ахиллесова пята (Network Latency Bottleneck):** Умножение долей требует постоянной синхронизации. Архитектурно применимо только в LAN или выделенных WAN-каналах (ping < 20 мс).
- **Use-case:** Агрегация градиентов и обучение неглубоких моделей (XGBoost, Логистическая регрессия).



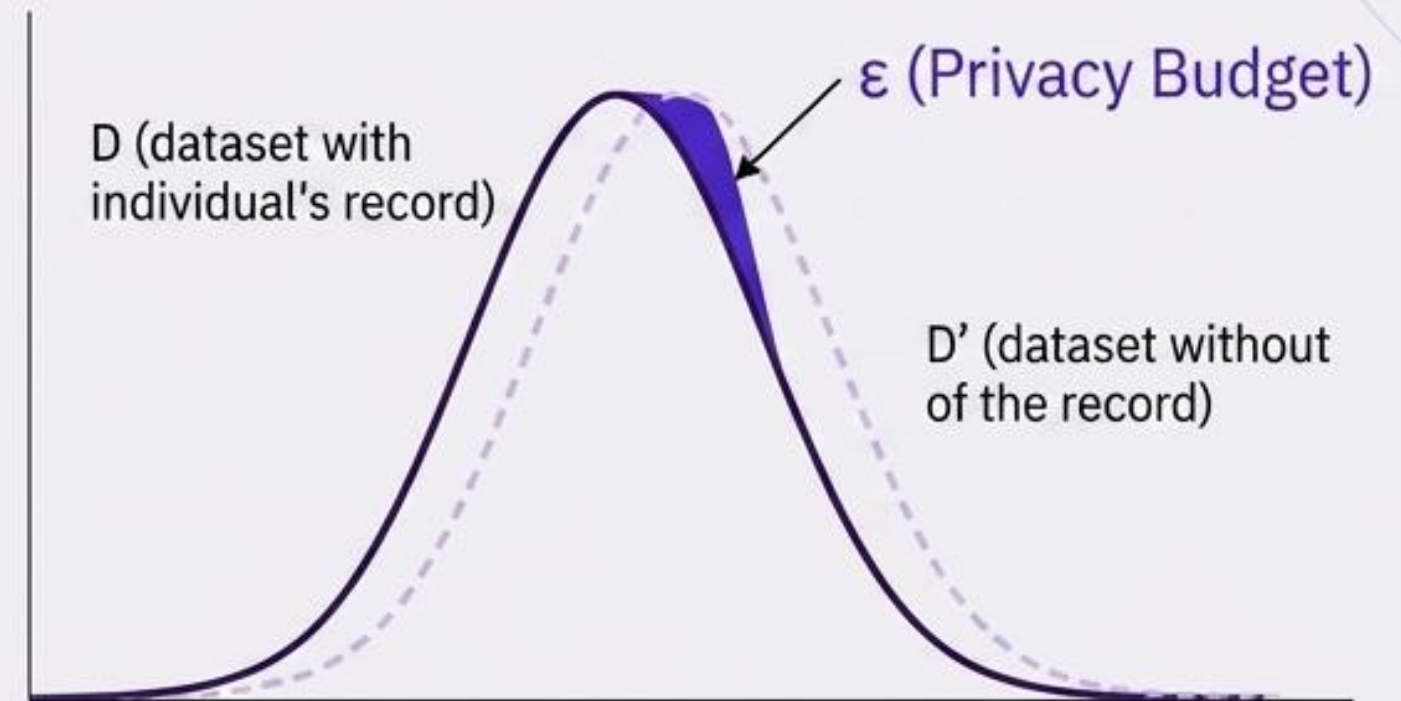
Сравнение фреймворков для SMPC

Фреймворк	Экосистема	Особенности	Минусы
SecretFlow (Ant Group)	Промышленная (Enterprise)	Комбайн (SMPC, FHE, TEE, FL). Идеально работает поверх Ray-кластеров. Готовые MPC-XGBoost модели.	Монструозная микросервисная архитектура, сложный дебаг.
MP-SPDZ	Академическая (R&D)	Более 40 протоколов (SPDZ, MASCOT). Наивысшая скорость (миллионы умножений/сек).	Специфичный язык s-c, нет out-of-the-box интеграции с PyTorch.
CrypTen (Meta)	ML-Native (PyTorch)	Автоконвертация графов PyTorch в SMPC (crypten.cryptensor), GPU-ускорение.	Разработка и поддержка сообществом сильно замедлилась к 2026 г.

Differential Privacy (DP): Суть и математическая база

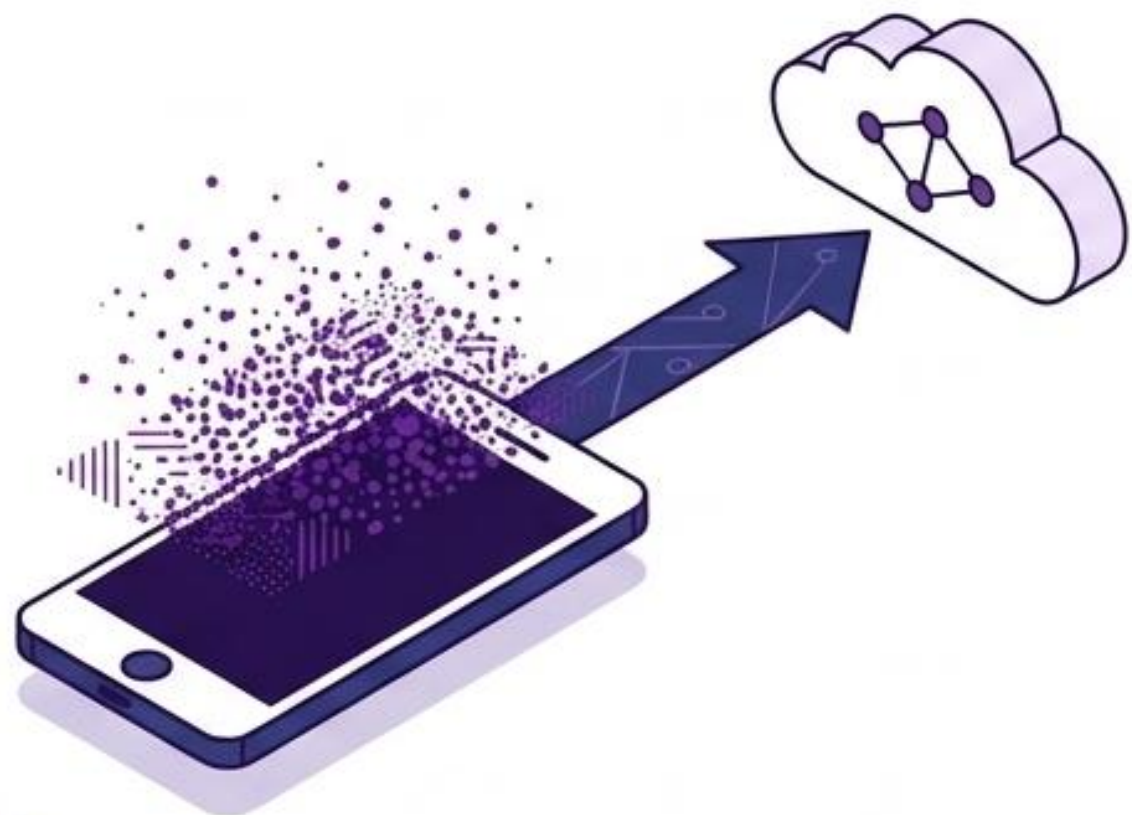
- **Математическая гарантия:** Строгое математическое доказательство того, что выходные данные алгоритма не позволят определить присутствие конкретной записи в обучающей выборке.
- **Механизм защиты:** Добавление калиброванного статистического шума в процессе вычисления градиентов (DP-SGD).
- **Параметры:**
 - ϵ (Privacy Budget) — допустимая граница утечки информации (индистингвируемость).
 - δ — вероятность того, что гарантия приватности будет нарушена.

The DP Math Visual



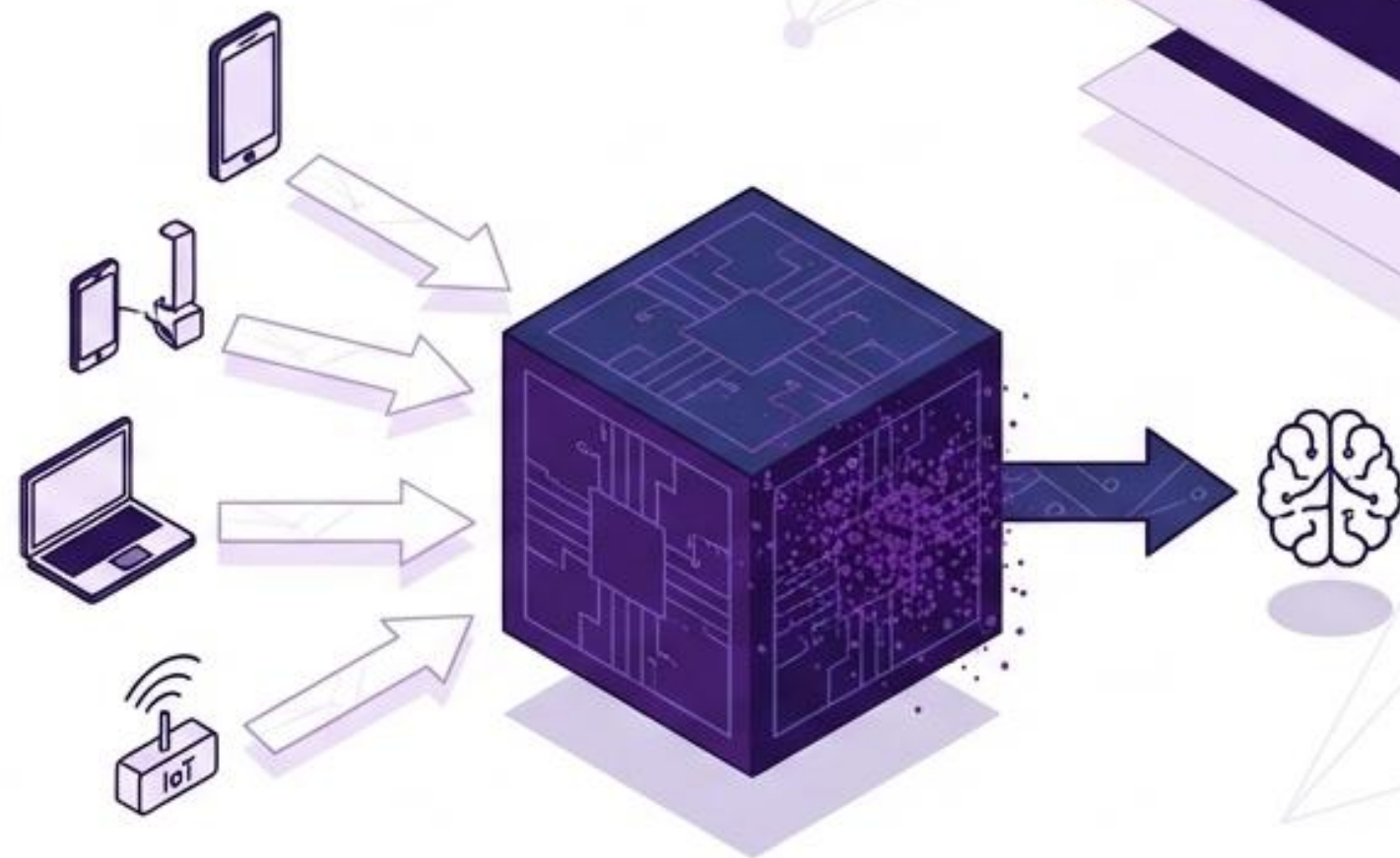
$$\Pr[M(D) \in \mathbb{R}] \leq e^{\epsilon} \Pr[M(D') \in \mathbb{R}] + \delta$$

Паттерны применения DP: Local vs Global DP



Trust Nobody

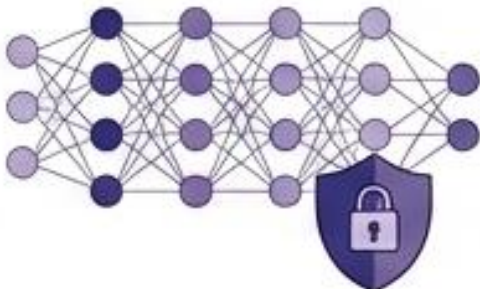
Local Differential Privacy (LDP): Шум вносится на стороне клиента до отправки данных. Сервер получает уже зашумленные данные. Обеспечивает максимальную приватность, но резко снижает сходимость модели.



Trusted Aggregator

Global Differential Privacy (Central DP): Сервер аккумулирует чистые данные (или градиенты) и добавляет шум на этапе финальной агрегации. Требуется доверия к агрегатору, но сохраняет высокую итоговую точность модели (Model Utility).

Сравнение фреймворков и библиотек Differential Privacy

Библиотека	Primary Use Case	Особенности
Opacus (PyTorch)	Глубокое обучение (DP-SGD) 	Эффективное вычисление per-sample градиентов через `einsum`. Высочайшая производительность в экосистеме PyTorch.
TensorFlow Privacy	ML в экосистеме Google 	XLA-driven JIT компиляция и продвинутая векторизация.
Google DP Core (C++/Java/Go)	Аналитические хранилища (Data Warehouses) <pre>SELECT query, aggregation COUNT/SUM, from COUNT/SUM, now gradient ...</pre> 	DP-аналитика данных (SQL-запросы, агрегации COUNT/SUM). Не ориентирован на градиентное обучение нейросетей.

White-Box Угрозы: Model Inversion и Data Extraction

Доступ к сырым градиентам эквивалентен доступу к исходным данным



Архитектурный Mitigation: DP-SGD (Differential Privacy)

Суть уязвимости:

Gradients (производные Loss-функции) сохраняют математические следы обучающих данных. Голый Federated Learning не защищает от утечек.



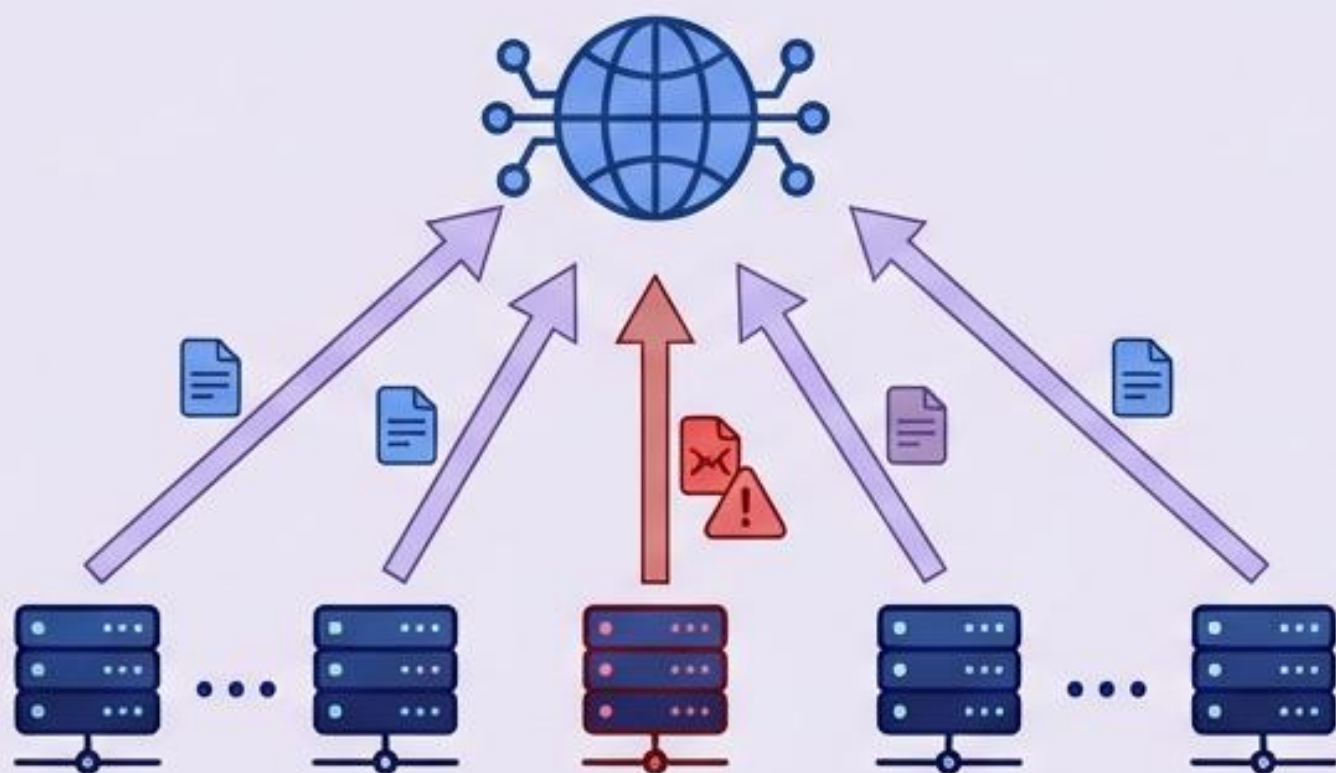
Векторы атак:

- Model Inversion (DLG): Итеративное восстановление данных из градиентов.
- Membership Inference: Вывод принадлежности записи к выборке через Black-Box анализ.

Угрозы РРА: Отравление данных и моделей

Вредоносное влияние на глобальную модель в распределенных системах

Data Poisoning (Отравление выборки)



Механика: Искажение локальной разметки клиентом или внедрение скрытых триггеров (Backdoors) в сырые данные.
Масштаб угрозы: Локальный. Требует компрометации значительного числа узлов консорциума для влияния на глобальную модель.

Model Poisoning (Отравление весов)



Механика: Прямая модификация вектора весов злоумышленником перед отправкой на сервер.
Scaling Attack: Умножение вредоносного вектора на огромное число. Один узел способен перевесить сотни честных обновлений (FedAvg).

Слой защиты: Отказ от простого усреднения. Интеграция робастных агрегаций (BFT): Krum, Median, Trimmed Mean, Bulyan. Фильтрация выбросов через косинусное расстояние.

Архитектурный парадокс: Конфликт приватности и Византийской отказоустойчивости

Балансировка криптографии и Byzantine Fault Tolerance (BFT)



State-of-the-Art Архитектура (Zero Trust):

- **ZKP** (zk-SNARK) + **FHE**: Клиент присылает криптографическое доказательство корректности нормы вектора (Clipping Bound), не раскрывая сам вектор.
- **Итог**: Сервер аппаратно отбрасывает вредоносные шифротексты ДО этапа гомоморфного сложения.

Управление ключами (KMS) в On-Premise PPA

Жизненный цикл криптографии в условиях суверенной инфраструктуры

Storage Engine (Consul / Raft) - Кластеризация хранилища для High Availability.

Hardware Security Module (HSM) - Безопасный старт и паттерн Auto-Unseal.

Self-Hosted KMS (HashiCorp Vault / CryptoPro)

Фундамент безопасности:
Компрометация Private Key (FHE/SecAgg) уничтожает всю систему конфиденциальности.
Использование Public Cloud KMS (AWS/GCP) физически и юридически недоступно в закрытых контурах.

PKI Transit Secrets - Динамическая ротация сертификатов узлов.

Правило Архитектора:
Внедрение Threshold Secret Sharing. Полный ключ дешифровки никогда не должен храниться ни на одном сервере целиком.

Federated Operations (FedOps) в Kubernetes

Контейнерная оркестрация тяжелых криптографических вычислений



Сетевой слой и Изоляция:

Обязательный Mutual TLS (mTLS) на Ingress. Service Mesh (Cilium/eBPF) для гранулярных Network Policies без оверхеда.



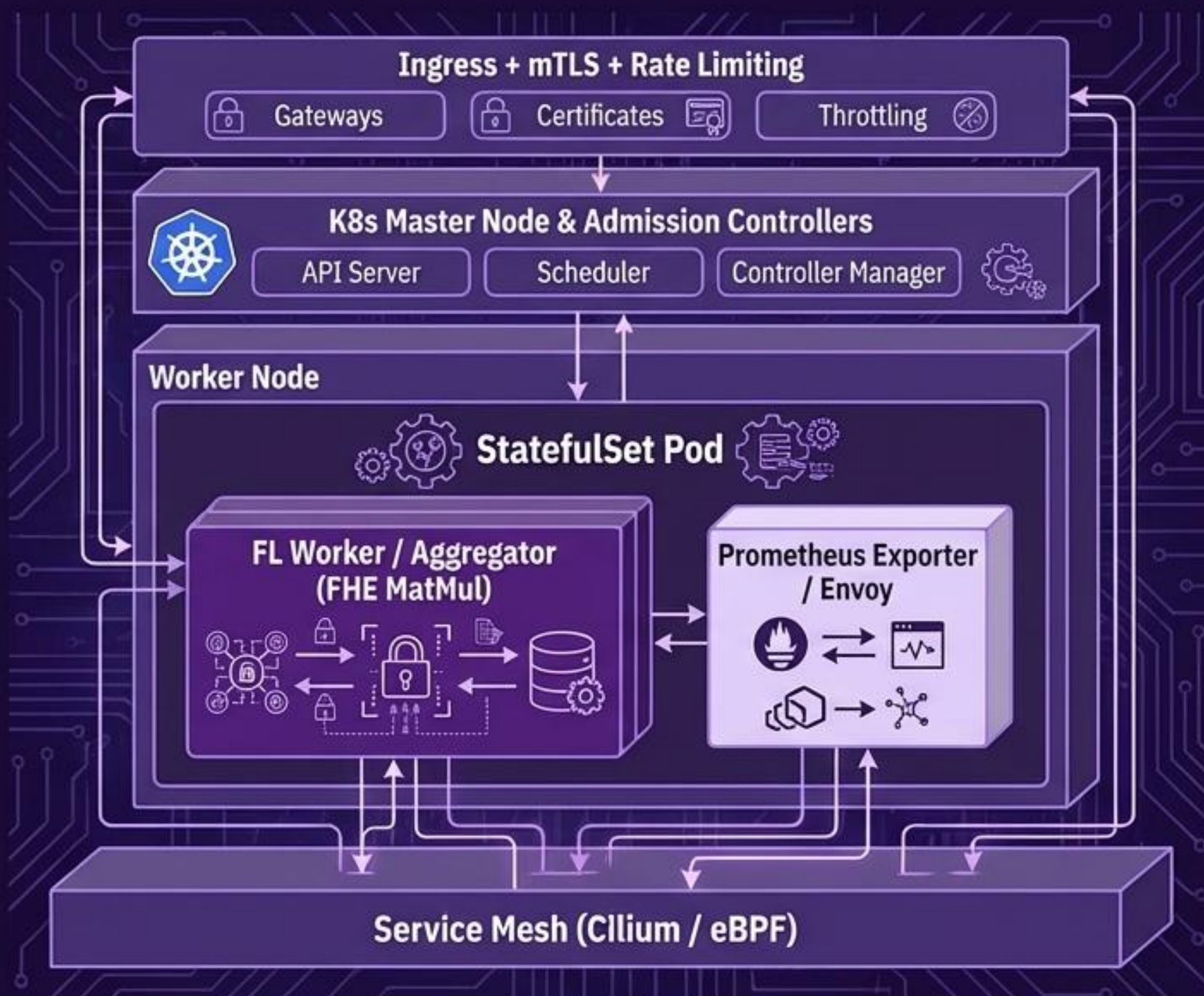
Управление ресурсами (Compute):

Использование StatefulSet с жестким контролем resources.requests/limits. Защита от OOM Kills при перемножении гигантских FHE-полиномов. Тюнинг gRPC (TCP Keep-Alive) для многочасовых сессий.



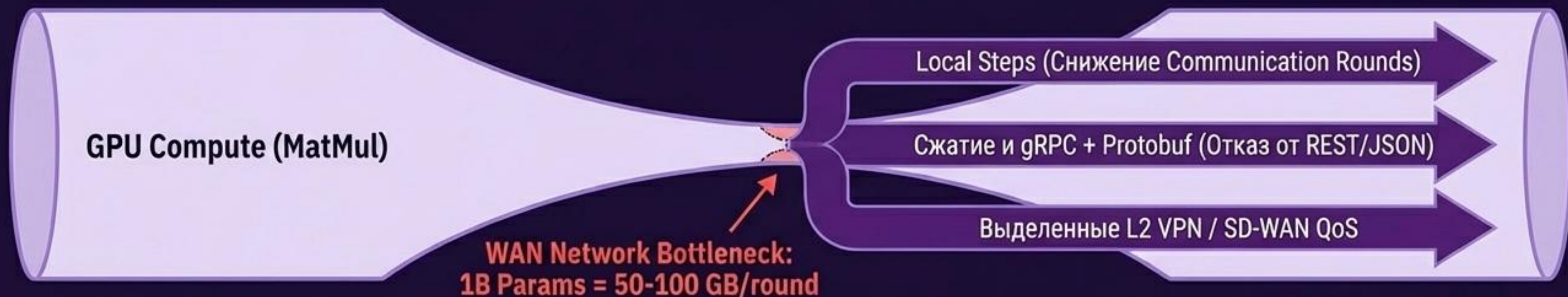
Observability (Мониторинг):

Sidcar-паттерн для учета Privacy Budget, GPU-метрик (через DCGM) и трейсинга RTT-задержек.



Data Plane: Преодоление сетевого коллапса (Bottleneck)

Управление пропускной способностью и Latency при обмене FHE-тензорами



Проблема:

Гомоморфное шифрование (FHE) модели на 1 млрд параметров генерирует 50-100 ГБ трафика за один раунд.

Паттерн Local Steps:

Выполнение 100-500 локальных эпох градиентного спуска клиентом перед отправкой апдейта агрегатору.

Протокольная база:

Строгий отказ от REST/JSON. Использование только gRPC + Protobuf/FlatBuffers для устранения оверхеда сериализации тензоров.

Толерантность к задержкам:

Переход к Asynchronous PPA. Внедрение Timeout Policies для отсеечения медленных узлов (Stragglers) без блокировки пайплайна.

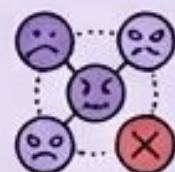
Threat Modeling (STRIDE / DREAD)

Картография границ доверия (Trust Boundaries) и векторов атак в РРА



Honest-but-Curious Server

- **Вектор:** Анализ логов и сырых градиентов сервером-агрегатором.
- **Защита:** Внедрение Secure Aggregation (FHE/SMPC) и Differential Privacy.



Malicious Clients (Вредоносные узлы)

- **Вектор:** Sybil Attacks, Data/Model Poisoning, DDoS консорциума.
- **Защита:** BFT-агрегация, строгий mTLS, Rate Limiting.



Inference API Attacks

- **Вектор:** Model Extraction, Adversarial Examples в Production.
- **Защита:** Внедрение AI Gateway (ML Firewall) — валидация промптов, детектирование аномальной частоты запросов.



Infrastructure Compromise

- **Вектор:** Container Escape и взлом K8s при отсутствии TEE.
- **Защита:** Immutable Infrastructure, Read-Only Root FS, политики SELinux/AppArmor.

Защита архитектурного дизайна на Architecture Review Board (ARB)

Выстраивание технической аргументации перед C-Level



CISO
(Директор по ИБ)

«Что, если хакер получит root-доступ к серверу агрегатора?»



«Сервер видит исключительно FHE-шифротексты. Ключи дешифровки разделены (Threshold Secret Sharing) между участниками консорциума. Необходима синхронная компрометация большинства».



СТО
(Технический директор)

«Зачем нам запрашивать бюджет на новые GPU-кластеры?»



«Криптографический overhead FHE/SMPC увеличивает потребление CPU/VRAM в 15 раз. Старое железо приведет к сетевым таймаутам и параличу всего консорциума».



Lead Data Scientist

«Насколько деградирует Accuracy из-за внедрения Differential Privacy?»



«Мы откалибровали Privacy Budget (ϵ). Падение точности составит не более 1.5%, что полностью окупается соответствием 152-ФЗ и возможностью легальной дата-монетизации».

Enterprise-Ready PPA Checklist

Финальная проверка готовности системы к Production и интеграции в КИИ

Архитектура и Сеть

- ✓ Определена Topology (Cross-Silo / Cross-Device, Hub vs P2P).
- ✓ Выбран FL фреймворк с поддержкой гетерогенности железа консорциума.
- ✓ Внедрено векторное квантование и сжатие градиентов для оптимизации Data Plane.

Криптография и Приватность

- ✓ Выбран и протестирован механизм Secure Aggregation (FHE или SMPC).
- ✓ Рассчитан Privacy Budget (ϵ) для Local Differential Privacy (защита от Inversion-атак).
- ✓ Реализован слой BFT-агрегации для аппаратной фильтрации Poisoning атак.

Безопасность и FedOps

- ✓ Спроектирован On-Premise KMS (Vault/КриптоПро) с авторотацией ключей.
- ✓ Настроен mTLS на уровне Ingress и Service Mesh.
- ✓ Настроен Capacity Planning кластеров и Sidcar-мониторинг узлов-stragglers.

Источники и Литература

Фундаментальные работы по проектированию Privacy-Preserving Architecture

A Pragmatic Introduction to Secure Multi-Party Computation (Evans, Kolesnikov, Rosulek)

Анализ BGW, GC, BMR и фундаментальных паттернов управления ключами в MPC.

Building Secure and Reliable Systems (Google SRE & Security)

Проектирование системных трейд-оффов, управление KMS, Graceful Degradation и Zero Trust (BeyondCorp).

FATE: An Industrial Grade Platform for Collaborative Learning With Data Protection (WeBank)

Реализация промышленных стандартов Vertical / Horizontal Federated Learning.

Federated Machine Learning: Concept and Applications (Yang et al.)

Математические и архитектурные основы паттернов Secure Aggregation.

The Algorithmic Foundations of Differential Privacy (Dwork, Roth)

Математическое обоснование DP, калибровка Privacy Budget и защита от Model Inversion.

TensorFlow Privacy / Opacus (PyTorch)

Технический инструментарий для реализации DP-SGD на уровне фреймворков.

Практика
